مقيد

شركة القيروان لنظم المعلومات

خطة الاستجابة لحوادث الأمن السيبراني

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · مرحلة التشغيل

رقم الوثيقة	**QIS-IRP-001**
الإصدار	٠٫٤ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

ضبط الوثيقة

الدور	المسمى الوظيفي	الاسم	الحالة
المالك	قائد الحوكمة والمخاطر والالتزام (مالك مؤقت حتى تعيين رئيس إدارة الأمن السيبراني)	نايف السالم	مكتمل
المراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	قيد الانتظار
المصادِق	اللجنة الإشرافية للأمن السيبراني	—	قيد الانتظار
المعتمِد	الرئيس التنفيذي	فيصل الحربي	قيد الانتظار

سجل الإصدارات

الإصدار	التاريخ	المُعِدّ	التغيير
٠٫١	٥ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى للمراجعة
٠٫٢	٩ نوفمبر ٢٠٢٦م	نايف السالم	تحديث مصدر مهلة إبلاغ الهيئة، وتطبيق مشروع تعديل اللائحة التنفيذية لنظام حماية البيانات الشخصية (الإبلاغ عن كل تسرب)
٠٫٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسوم أمن المعلومات (التصنيف، والعلامة المائية، وإشارة المشاركة وفق مستويات الهيئة الوطنية للأمن السيبراني)، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠٫٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

دورة المراجعة: سنوياً على الأقل، وبعد كل حادثة حرجة أو مرتفعة الخطورة، وعند أي تغيير جوهري في البنية التقنية أو الخدمات أو المتطلبات التنظيمية.

التصنيف وإشارة المشاركة

الوسم	المستوى	ما يعنيه
التصنيف	مقيد	يؤدي الإفصاح غير المصرح به إلى ضرر محدود، ويقتصر الاطلاع على من تحددهم الشركة.
إشارة المشاركة (TLP)	برتقالي	مشاركة محدودة داخل جهة المستلم مع المعنيين فقط.

التوزيع: الرئيس التنفيذي، وأعضاء فريق الاستجابة للحوادث، واللجنة الإشرافية، ومسؤول حماية البيانات الشخصية. لا تُشارك خارج الشركة إلا بموافقة قائد الحوكمة والمخاطر والالتزام، ويُستثنى من ذلك تزويد العملاء بنسخة موجزة عند الطلب التعاقدي.

١. الغرض والنطاق

١٫١ الغرض

تحدد هذه الخطة كيف تكتشف شركة القيروان لنظم المعلومات حوادث الأمن السيبراني وتصنفها وتحتويها وتزيلها وتتعافى منها وتُبلغ عنها، وكيف تفي بالتزاماتها تجاه عملائها الحكوميين والجهات التنظيمية. وهي تعالج الخطر R-16 في سجل المخاطر.

١٫٢ النطاق

تشمل الخطة جميع أنظمة الشركة وشبكاتها وبياناتها، والأنظمة التي تستضيفها أو تبنيها أو تديرها للعملاء من (أ) إلى (و)، وصلاحيات الوصول إلى شبكات العملاء عبر أداة الإدارة عن بُعد، والخدمات التي يقدمها مزوّد الخدمات السحابية. وتنطبق على جميع الموظفين والمتعاقدين والأطراف الخارجية العاملة لصالح الشركة.

١٫٣ خارج النطاق

- الحوادث داخل أنظمة العملاء التي لا تديرها الشركة، ما لم يطلب العميل دعمها بموجب العقد.
- حوادث الأمن المادي التي لا يرتبط بها بُعد سيبراني.
- طلبات الدعم الفني الاعتيادية التي لا تحمل أثراً أمنياً.

٢. الإطار التنظيمي والتعاقدي

الشركة مزوّد خدمة لجهات حكومية، فتلتزم بالاستجابة للحوادث بموجب عقودها مع العملاء، وتدعمهم في الوفاء بالتزاماتهم تجاه الجهات التنظيمية.

الجهة	الإطار	سبب انطباقه	الالتزام الرئيس
العملاء الحكوميون	عقود الخدمة وبنود معالجة البيانات	تدير الشركة أنظمتهم وتعالج بياناتهم	إبلاغ العميل خلال المهل التعاقدية، ودعم التحقيق والتعافي
الهيئة الوطنية للأمن السيبراني	الضوابط الأساسية للأمن السيبراني (ECC-2:2024)، المكوّن الفرعي ٢-١٣	يطبق العملاء الضوابط على مزوّدي خدماتهم	خطة موثقة للاستجابة، وتصنيف الحوادث، والإبلاغ عبر منصة «حصين» عند الاقتضاء
الهيئة الوطنية للأمن السيبراني	ضوابط الأمن السيبراني للحوسبة السحابية (CCC)	تستضيف الشركة أنظمة حكومية على السحابة	تنسيق الاستجابة مع مزوّد السحابة وفق المسؤولية المشتركة
سدايا	نظام حماية البيانات الشخصية ولائحته التنفيذية	الشركة جهة معالجة لبيانات شخصية لصالح العملاء	إبلاغ جهة التحكم فوراً عن كل تسرب لتتمكن من إبلاغ سدايا خلال ٧٢ ساعة

٣. التعريفات

المصطلح	التعريف
حادثة أمن سيبراني	أي حدث يهدد فعلياً أو احتمالياً سرية أنظمة الشركة أو عملائها أو بياناتهم أو سلامتها أو توافرها.
حادثة جوهرية	حادثة بمستوى خطورة حرج أو مرتفع وفق القسم ٥، وتستلزم إبلاغ العميل.
خرق البيانات الشخصية	وصول أو كشف أو تعديل أو فقدان أو إتلاف غير مصرح به لبيانات شخصية.
فريق الاستجابة (CSIRT)	الفريق المسؤول عن تنفيذ الاستجابة الفنية والتنسيق أثناء الحادثة.
مؤشر الاختراق (IOC)	دليل فني على وقوع اختراق، كعنوان أو ملف أو نشاط مشبوه.
RTO / RPO	زمن التعافي المستهدف / نقطة الاستعادة المستهدفة، وفق خطة استمرارية الأعمال.

٤. الأدوار والمسؤوليات

الدور	من يشغله	المسؤولية أثناء الحادثة
قائد الحادثة	قائد الحوكمة والمخاطر والالتزام (مؤقتاً)	يملك إدارة الحادثة، ويعتمد تصنيف الخطورة، وهو جهة الاتصال مع العملاء والجهات التنظيمية.

الدور	من يشغله	المسؤولية أثناء الحادثة
قائد الفريق الفني	كبير مهندسي الأمن السيبراني	ينسق الاحتواء والإزالة والتعافي الفني.
أعضاء الفريق الفني	مهندس الأمن، والعمليات التقنية، والاستضافة، والتطوير، ومركز العمليات الأمنية المُدار	الكشف والتحقيق والمعالجة الفنية.
مسؤول حماية البيانات الشخصية	قائد الحوكمة والمخاطر والالتزام	تقييم أثر الحادثة على البيانات الشخصية، وإبلاغ جهة التحكم.
منسق العملاء	رئيس تقديم الخدمات	التواصل اليومي مع فرق العملاء التقنية، وتنفيذ إجراءات الاحتواء في الخدمات المُدارة.
الشؤون القانونية والعقود	الرئيس التنفيذي للمالية	مراجعة الالتزامات التعاقدية، والتواصل مع الجهات القانونية، والتعامل مع حوادث الموظفين والمتعاقدين.
فريق إدارة الأزمة	الرئيس التنفيذي والرئيس التنفيذي للتقنية والرئيس التنفيذي للمالية	قرارات الأعمال والموارد في الحوادث الحرجة، واعتماد الرسائل الخارجية.

يلتزم مزوّد الخدمات السحابية ومركز العمليات الأمنية المُدار بإبلاغ الشركة بأي حادثة تمس خدماتها أو بياناتها خلال ٤ ساعات للحوادث الحرجة، وفق ما تنص عليه عقودهم. ويحتفظ قائد الحادثة بسجل لجهات الاتصال الأمنية لدى الأطراف الخارجية ومهل الإبلاغ التعاقدية.

٥. تصنيف خطورة الحوادث

المستوى	التعريف	مثال من الشركة	بدء الاستجابة	التصعيد
حرج	اختراق مؤكد يمس عدة عملاء أو بيانات شخصية واسعة، أو توقف خدمة حرجة	انتشار برمجية فدية عبر أداة الإدارة عن بُعد إلى شبكات العملاء، أو كشف بيانات المواطنين من البوابة	فوراً، خلال ساعة	الرئيس التنفيذي وفريق إدارة الأزمة، وتفعيل الفريق كاملاً
مرتفع	حادثة ذات أثر ملموس على عميل واحد أو خطر تصاعد	اختراق حساب فني لديه صلاحيات وصول إلى شبكة عميل	خلال ٤ ساعات	قائد الحادثة والرئيس التنفيذي للتقنية
متوسط	حادثة محتواة ذات أثر محدود داخل الشركة	برمجية خبيثة معزولة على حاسب واحد	خلال ٢٤ ساعة	قائد الفريق الفني
منخفض	حدث بسيط أو معلوماتي	محاولة تصيد محجوبة، أو مخالفة لسياسة الاستخدام	ضمن العمل الاعتيادي	تسجيل فقط

٦. دورة حياة الاستجابة

#	المرحلة	الأنشطة الرئيسة
١	الاستعداد	تحديث قائمة الفريق وجهات الاتصال، وجاهزية أدوات المراقبة والكشف، وأدلة الاستجابة لكل نوع حادثة، والتدريب السنوي.
٢	الكشف والتحليل	فرز التنبيهات، وتأكيد النطاق، وتحديد مستوى الخطورة، وفتح سجل الحادثة وتسلسلها الزمني.
٣	الاحتواء	عزل الأنظمة أو الحسابات المتأثرة، وإيقاف وصول أداة الإدارة عن بُعد إلى العملاء عند الحاجة، وإلغاء بيانات الدخول المخترقة، مع حفظ الأدلة قبل أي إجراء يتلفها.
٤	الإزالة	إزالة السبب الجذري ومعالجة الثغرة المستغلة، لا العَرَض فقط.
٥	التعافي	الاستعادة من نسخ احتياطية سليمة ومتحقق منها، ومراقبة عودة الإصابة، وتأكيد التشغيل الطبيعي مع مالك النظام والعميل.
٦	ما بعد الحادثة	تحليل السبب الجذري، وتقرير الدروس المستفادة، ومتابعة إجراءات التحسين حتى إغلاقها.

معايير إغلاق الحادثة

- التأكد من سلامة الأنظمة المتأثرة ومراقبتها مدة تتناسب مع خطورة الحادثة.
- معالجة السبب الجذري أو الثغرة المستغلة.
- موافقة مالك النظام، والعميل عند تأثره، على عودة التشغيل الطبيعي.
- إتمام جميع الإبلاغات المطلوبة في القسم ٨، أو تسجيل ما بقي منها معلقاً.
- اكتمال نموذج تقرير الحادثة (الملحق ب).
- تسجيل قائد الحادثة للإغلاق وتاريخه ومبرره.

٧. الكشف والتصعيد الداخلي

مصادر الكشف: تنبيهات مركز العمليات الأمنية المُدار، وأدوات الكشف والاستجابة على الأجهزة، وبلاغات العملاء، وبلاغات الأطراف الخارجية، وبلاغات الموظفين عبر البريد security@qis.example أو الرقم الداخلي ٢١٠٠.

الوقت من الكشف	الإجراء	المسؤول
خلال ١٥ دقيقة	تسجيل الحادثة، والفرز الأولي، والتصنيف المبدئي	مهندس الأمن المناوب أو مركز العمليات الأمنية

الوقت من الكشف	الإجراء	المسؤول
خلال ٣٠ دقيقة	تأكيد التصنيف، وإبلاغ قائد الحادثة في الحوادث المتوسطة فما فوق	قائد الفريق الفني
خلال ساعة	تفعيل الفريق الكامل وإبلاغ الرئيس التنفيذي في الحوادث الحرجة	قائد الحادثة
وفق القسم ٨	إبلاغ العملاء والجهات التنظيمية	قائد الحادثة ومسؤول حماية البيانات

٨. متطلبات الإبلاغ الخارجي

الجهة	متى	المهلة	القناة	المحتوى
العميل المتأثر	أي حادثة تمس أنظمته أو بياناته أو خدماته	٤ ساعات للحوادث الحرجة والمرتفعة، و٢٤ ساعة كحد أقصى لغيرها	جهة الاتصال الأمنية المحددة في العقد	ملخص الحادثة، والأنظمة والبيانات المتأثرة، وإجراءات الاحتواء، وموعد التحديث التالي
الهيئة الوطنية للأمن السيبراني	عند اشتراط العميل أو الهيئة إبلاغ الشركة مباشرة	وفق تعليمات الهيئة والعميل، وبحد أقصى ٢٤ ساعة	منصة «حصين»	التفاصيل الفنية، ومؤشرات الاختراق، وتقييم الأثر، وإجراءات المعالجة
جهة التحكم (العميل) لأغراض نظام حماية البيانات	خرق بيانات شخصية يعالجها نيابة عن العميل	فوراً، وبحد أقصى ٢٤ ساعة من الاكتشاف	مسؤول حماية البيانات لدى العميل	طبيعة الخرق، وفئات البيانات وعدد أصحابها التقريبي، والعواقب المحتملة، والإجراءات المتخذة
مزوّد الخدمات السحابية	حادثة تمس الأنظمة المستضافة أو تتطلب دعمه	فوراً	قناة الدعم الأمني لدى المزوّد	المعلومات اللازمة للاحتواء والتحقيق فقط

قد تستلزم الحادثة الواحدة عدة إبلاغات في وقت واحد، فيحدد قائد الحادثة من يُعدّ كل إبلاغ منذ البداية حتى لا تتنافس المهل على الأشخاص أنفسهم.

٨٫١ سجل التحقق من المهل النظامية

الجهة	المهلة الواردة أعلاه	المصدر	حالة التحقق
الهيئة الوطنية للأمن السيبراني	٢٤ ساعة كحد أقصى	واجب الإبلاغ من المكوّن الفرعي ٢-١٣ في الضوابط الأساسية (ECC-2:2024)، والمهلة كما أكدها مختص في الحوكمة والمخاطر والالتزام	يُطابق مع النص الرسمي للضوابط قبل الاعتماد
سدايا	٧٢ ساعة لإبلاغ جهة التحكم سدايا، لكل تسرب أياً كان أثره	اللائحة التنفيذية لنظام حماية البيانات الشخصية، ومشروع تعديلها (أكتوبر ٢٠٢٦م)	تقصر اللائحة الحالية الإبلاغ على التسرب الذي قد يسبب ضرراً، ويوسّعه مشروع التعديل ليشمل كل تسرب. تطبّق الشركة الحكم الأشد من الآن
العملاء	٤ ساعات / ٢٤ ساعة	عقود الخدمة وبنود معالجة البيانات	يُتحقق منها من كل عقد

٩. خطة التواصل

الجمهور	متى	المسؤول	القناة	المتطلبات
فريق الاستجابة	فور تأكيد الحادثة وعند كل تغيير جوهري	قائد الحادثة	قناة اتصال آمنة مخصصة للحادثة	رقم الحادثة وخطورتها، والحقائق المؤكدة، والقرارات، وموعد التحديث التالي
الإدارة العليا	الحوادث الحرجة والمرتفعة، وعند تغيّر الأثر	قائد الحادثة	اجتماع أو اتصال آمن وتقرير موجز	الأثر على الأعمال والعملاء، وحالة التعافي، والقرارات المطلوبة
العملاء المتأثرون	وفق القسم ٨، ثم دورياً حتى الإغلاق	قائد الحادثة ومنسق العملاء	جهة الاتصال الأمنية التعاقدية	رسالة واحدة متسقة بالحقائق المؤكدة فقط
الجهات التنظيمية	عند الاقتضاء وفق القسم ٨	قائد الحادثة	القنوات الرسمية	جهة اتصال واحدة، وتوثيق كل إرسال وإقرار استلام
الموظفون	عند الحاجة لإجراء منهم	قائد الحادثة	البريد الداخلي	التعليمات المطلوبة دون تفاصيل حساسة

الجمهور	متى	المسؤول	القناة	المتطلبات
الإعلام	لا تتواصل الشركة مع الإعلام إلا بالتنسيق مع العميل المعني	الرئيس التنفيذي	بيان معتمد	لا تخمين، ولا إفصاح عن تفاصيل الحادثة أو هوية العميل

١٠. حفظ الأدلة والتحليل الجنائي

- تُحفظ السجلات وصور الذاكرة والأقراص وسجلات الأنظمة السحابية قبل أي إجراء معالجة قد يتلفها، متى كان ذلك ممكناً وآمناً.
- يُوثَّق تسلسل حيازة كل دليل: مصدره، ومن جمعه، ووقت الجمع، وكل انتقال له، وقيمة التجزئة للتحقق من سلامته.
- تُحفظ الأدلة في مستودع آمن محدود الوصول.
- تُحفظ سجلات الأحداث الأمنية ١٢ شهراً على الأقل، أو أكثر إذا اشترط العقد أو النظام ذلك.
- يُستعان بجهة تحليل جنائي خارجية في الحوادث الحرجة أو عند طلب العميل أو الجهات المختصة.

١١. الربط مع خطة استمرارية الأعمال

إذا تسببت الحادثة في توقف خدمة، تُفعَّل خطة استمرارية الأعمال (QIS-BCP-001) بالتوازي مع هذه الخطة. يملك فريق الاستجابة الجانب الأمني (الاحتواء والإزالة والتحقيق)، ويملك فريق الاستمرارية استعادة الخدمة، ويُنسق فريق إدارة الأزمة بين المسارين حتى لا يعملا منفصلين.

١٢. المراجعة بعد الحادثة

الخطوة	التوقيت	المسؤول
جلسة الدروس المستفادة	خلال ٥ أيام عمل من الإغلاق	قائد الحادثة
تقرير السبب الجذري	بعد الجلسة، ويُرفع إلى اللجنة الإشرافية	قائد الحادثة
متابعة الإجراءات التصحيحية	حتى إغلاقها، وتُسجل المخاطر الجديدة في QIS-RR-001	مالكو الإجراءات
تحديث الخطة عند ظهور ثغرات فيها	عند الحاجة	مالك الخطة

١٣. الاختبار والتدريب والصيانة

النشاط	الدورية	التفاصيل
تمرين محاكاة	سنوياً على الأقل	سيناريو من الملحق (ج)، بمشاركة منسق العملاء، ويُدعى عميل واحد على الأقل
التدريب	سنوياً لجميع الموظفين	مع تدريب إضافي متخصص لأعضاء فريق الاستجابة
مراجعة الخطة	سنوياً	وبعد كل حادثة حرجة أو تغيير تنظيمي جوهري

١٤. المقاييس ورفع التقارير

المقياس	التعريف	يُرفع إلى	الدورية
متوسط زمن الكشف (MTTD)	من وقوع الحادثة إلى اكتشافها	اللجنة الإشرافية	ربع سنوي
متوسط زمن الاحتواء (MTTC)	من الاكتشاف إلى الاحتواء	اللجنة الإشرافية	ربع سنوي
الحوادث حسب الخطورة	عدد الحوادث في كل مستوى	اللجنة الإشرافية	ربع سنوي
الالتزام بمهل إبلاغ العملاء	نسبة الإبلاغات المرسلة ضمن المهلة	اللجنة الإشرافية	ربع سنوي
إغلاق الإجراءات التصحيحية	نسبة الإجراءات المغلقة في موعدها	اللجنة الإشرافية	ربع سنوي

الملحق (أ). قائمة فريق الاستجابة

الدور	الاسم	التحويلة	البديل
قائد الحادثة	نايف السالم	٢١٠١	ريم العتيبي
قائد الفريق الفني	كبير مهندسي الأمن السيبراني	٢١٠٢	مهندس الأمن السيبراني
منسق العملاء	سلطان الدوسري	٢٢٠١	مشرف الخدمات المُدارة
الشؤون القانونية والعقود	ماجد القحطاني	٢٣٠١	مدير الموارد البشرية
فريق إدارة الأزمة	فيصل الحربي	٢٠٠١	ريم العتيبي
مركز العمليات الأمنية المُدار	يُحدد عند التعاقد (R-03)	—	—

تُحفظ أرقام الجوال وجهات الاتصال لدى العملاء في نسخة محدثة من هذا الملحق لدى قائد الحادثة، ولا تُنشر.

الملحق (ب). نموذج تقرير الحادثة

الحقل	المحتوى
رقم الحادثة وتاريخ الاكتشاف ووقته	
مصدر الكشف ومن أبلغ	
مستوى الخطورة ومبرره	
الأنظمة والعملاء والبيانات المتأثرة	
التسلسل الزمني للأحداث والإجراءات	
إجراءات الاحتواء والإزالة والتعافي	
الإبلاغات الخارجية: الجهة والوقت والمرجع	
السبب الجذري	
الدروس المستفادة والإجراءات التصحيحية	
الإغلاق: التاريخ والمعتمد	

الملحق (ج). أدلة الاستجابة المختصرة

ج-١ برمجية فدية تنتشر عبر أداة الإدارة عن بُعد (حرج)

- إيقاف أداة الإدارة عن بُعد وجميع اتصالات VPN بالعملاء فوراً بقرار من قائد الحادثة.
- عزل الأجهزة المصابة عن الشبكة دون إطفائها، وحفظ صور الذاكرة.
- إبلاغ جميع العملاء المتصلين خلال ٤ ساعات، حتى لو لم تثبت إصابتهم.
- تحديد سلالة البرمجية ونقطة الدخول، وإلغاء جميع بيانات الدخول الإدارية.
- الاستعادة من النسخ الاحتياطية غير القابلة للتعديل بعد التحقق من سلامتها، وتفعيل خطة استمرارية الأعمال.
- عدم دفع أي فدية أو التواصل مع المهاجمين إلا بقرار من فريق إدارة الأزمة وبالتنسيق مع الجهات المختصة.

ج-٢ اختراق حساب فني لديه وصول إلى شبكة عميل (مرتفع)

- تعطيل الحساب وإلغاء جلساته ومفاتيح الوصول فوراً.
- مراجعة سجلات أداة الإدارة عن بُعد وVPN لتحديد الأنشطة المنفذة لدى كل عميل.
- إبلاغ العميل المتأثر خلال ٤ ساعات، ومشاركته الأنشطة المشبوهة لفحص بيئته.
- التحقق من مصدر الاختراق (تصيد، أو كلمة مرور مكررة، أو جهاز مصاب) ومعالجته.

ج-٣ كشف بيانات المواطنين من البوابة (حرج)

- إيقاف واجهة البرمجة المستغلة أو تقييدها بقرار مشترك مع العميل (أ).
- حفظ سجلات البوابة وجدار حماية التطبيقات وقاعدة البيانات.
- تحديد السجلات المكشوفة وعدد أصحابها، وإبلاغ العميل (أ) بصفته جهة التحكم فوراً وخلال ٢٤ ساعة كحد أقصى.
- معالجة الثغرة واختبارها قبل إعادة التشغيل، وإجراء تقييم لأثر حماية البيانات.

مقيد